Protecting Your Bits: Easy Wins for Improving Your Personal Password Regime

trimarcsecurity.com/hub-post/protecting-your-bits-easy-wins-for-improving-your-personal-password-regime

Jake Hildreth October 3, 2022

Updated: Dec 13, 2024



The Dawn of the Password

There once was a man named Fernando Corbató who left a giant impact on the computing world. While you may not recognize his name, you've almost certainly interacted with his legacy *today*. Fernando Corbató is credited with bringing the ancient idea of the "password" to the computing world while working at the Massachusetts Institute of Technology (MIT) in the early 1960s.



Figure 1: Fernando Corbató

For much of the 60s, MIT had a single mainframe computer that was shared between multiple users via the Compatible Time-Sharing System (CTSS). To protect the files of individual users from being accessed by other users unintentionally or maliciously, Corbató suggested locking each user's files with a password. And thus, the password as we know it was born.

Over sixty years later, Corbató's contribution to information security remains the first line of defense in most modern computer environments. The lowly, simple password continues to be used for identification and authentication in almost every computer system and application known to humans because passwords are cheap and easy to implement. In addition, their long-lived existence means most computer users innately understand their use.

However, from the moment the password was introduced to computing, the limitations of such a system were obvious. Passwords are easy to guess, easy to break, and most dangerously, a potential single point of failure. The storage of passwords in a single file or database means an attacker can generally compromise an entire computer system if they can gain access to its password data.

An example of this was the initial CTSS password system. It was only secure for about a year! In 1962, MIT researcher Alan Scherr figured out how to submit a specially formatted punch card which would cause the system to print a hard copy of the CTSS password file. He used these passwords to modify the CTSS operating system and give himself additional time to do research. Old-timey hacks were so fun, but at the time, they were just known as timey hacks.

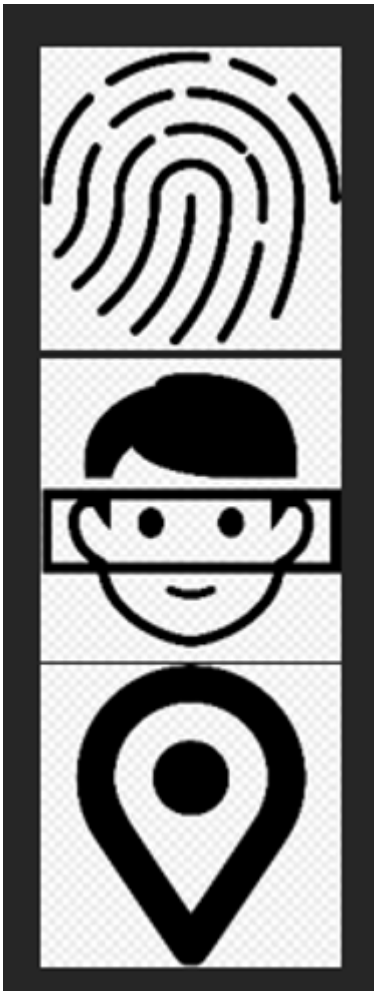
Modern Password Landscape

Thankfully, the password situation has improved since the 60s. Kind of. Passwords are still typically stored in centralized locations, but thanks to techniques developed in cryptography, passwords are no longer stored in human-readable text and cannot be printed (usually!). The average computer user is starting to understand the importance of password hygiene and how password sharing might be a bad idea.

More promisingly, passwordless authentication systems are becoming the new normal. These systems identify and authenticate users through situational information (location data, time of day); biometrics (physical traits, behavioral traits); physical devices (hardware tokens, one-time passwords); magic links; and a smattering of other related ideas. Passwordless systems offer a more secure identification and authentication experience by eliminating the need for the user to remember anything.

Currently, there are multiple options for both enterprise and consumer users to go passwordless. Biometric devices such as fingerprint scanners and facial recognition are now common technologies included in consumer products. However, as a society, we are just barely out of the first generation of internet users. If we're *ever* able to eliminate password use, it won't be any time soon. Since the completely passwordless future isn't here yet, it's important that passwords currently in use are as secure as possible.

Figure 2: Common Passwordless Authentication Factors



Numerous articles have been written about weak passwords and how to improve them. Most of the articles come to the same conclusions:

- Create a unique password for every site/application/system.
- Make sure your passwords are “complex” and “secure.”

While this is sound advice, very little explanation is given about what makes a password truly complex and secure. Users might believe they are creating “secure” passwords, but because passwords need to be easy for a human to remember, average users tend to create passwords that fall into one of these buckets:

Personally Identifiable Information (PII):

- Spot2017! (dog’s name and date of birth)
- March3,2015 (wedding anniversary)

Keyboard Walking (using the layout of the keyboard to create a pattern that is easy to remember):

- Asdfg7890-

- 0;9l8k7j6h

Random 3-4 Dictionary/Slang Words

And to meet complexity requirements, humans tend to use the following tricks:

Leetspeak (such hacker wow):

- 5p0t2017!
- M4rch3,2ol5

Prefix/Append numbers:

- Summer2020
- 12745Password

Prefix/Append special chars:

- Autumn2022?
- !GoBrowns!

Unfortunately, most users are not aware that attackers can abuse these password tricks, patterns, and tropes to greatly reduce the time required to guess their password. So even though your password may appear “complex” and “secure”, it’s probably still weak.

Enter The Password Manager

To help combat the issues with human-generated passwords, users should use a password manager and use it to create all passwords on the users' behalf. Computer-generated passwords eliminate many of the issues discussed above, but unfortunately there are still multiple ways to misuse and misconfigure a password manager which result in less security for the end user than expected.

Adding a password manager into your personal security regime also eliminates the need to make passwords easy-to-remember. The password manager never forgets, so the passwords it creates can be long, very complex, and incredibly random.

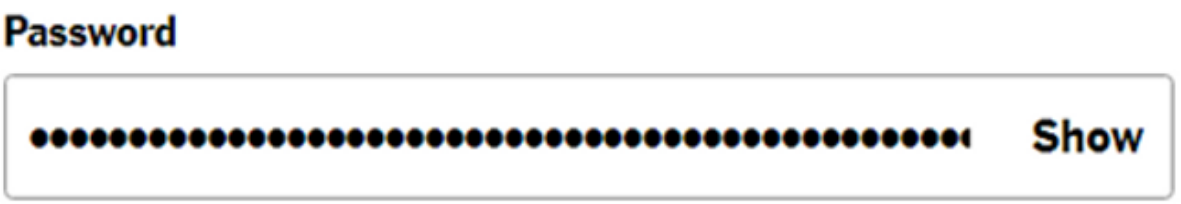


Figure 3: Your password manager can easily create and remember this beast!

Along with their elephant-like memory capacity, modern password managers can audit stored passwords and alert the user to compromised accounts and weak/reused credentials. Some password managers will even alert you if you stumble upon a malicious/phishing site. If you aren't using a password manager yet, it's time to get on the train!

Weak Primary Password

Unfortunately, password managers are only as secure as the factors protecting them, and the most important factor protecting your password manager is its primary password. This password should be long. Very long. No, even longer than you're thinking! Aim for a password at least 25 characters long. At this length, you do not need to worry about including wacky leetspeak or pure random characters. However, because you will likely be typing this password at least once a day, it *must* be easy to remember. Some good examples of long but easy to remember passwords are:

- A random line from an uncommon book
- A lyric from an uncommon song
- A series of 7 or 8 dictionary words
- Do not share this password with anyone.
- Do not record this password anywhere.



Figure 4: Out of print books are great source material for long but easy-to-remember primary passwords.

Primary Password Reuse

Again, password managers are only as secure as the factors protecting them! If the primary password for your personal password manager is identical to the primary password for your work password manager, change one or both passwords *immediately*. This tiny step effectively halves the blast radius of any potential compromise. To completely own your digital life, an attacker must now figure out two 25+ character primary passwords instead of just one. Unless you are the target of a nation-state, this is probably sufficient.

Time-based One-Time Passwords Stored in the Same App as Passwords

Using multiple apps or devices to protect your identity information sucks, so when people see that their password manager supports the storage of Time-based One-Time Passwords (TOTPs), they immediately migrate all their TOTPs out of their authenticator app(s) and into the password manager. This setup is incredibly easy to use! The password manager drops the TOTP into the user's clipboard at the appropriate time, and the user only needs to paste the code into the proper location. A second app or device is no longer required. It just works.

Unfortunately, this self-contained authentication ecosystem now holds all the user's passwords and secondary factors, and that entire ecosystem is protected with a single primary password. If that primary password is compromised, the user's entire digital life could be owned.

True multi-factor authentication requires at least 2 separate types of authentication factors. The most common factors are "something you know" (usually a password) and "something you have" (TOTP on a mobile device), but other frequently-used factors include "something you are" (biometrics) and "somewhere you are" (your location). Storing your "something you know" factor in the same app as your "something you have" factor means you have eliminated the "multi-" part of "multi-factor authentication."

Ultimately, multi-factor authentication only provides additional security when the factors involved are truly independent. *At the very least*, your passwords and TOTPs should exist in separate apps protected by separate complex passphrases and/or biometrics.

Knowledge-Based Authentication Answers Stored in Plaintext

A neat thing most password managers provide is the ability to store notes along with account credentials. Many users place the answers to Knowledge-Based Authentication (KBA) questions such as their mother's birth name or childhood nickname in these notes. Unfortunately, most password managers leave these notes unprotected and visible by

default. In this configuration, a person standing behind you could easily read your secret answers. To fix this problem, store your KBA answers in the same fashion you store passwords: marked as private and hidden from view.

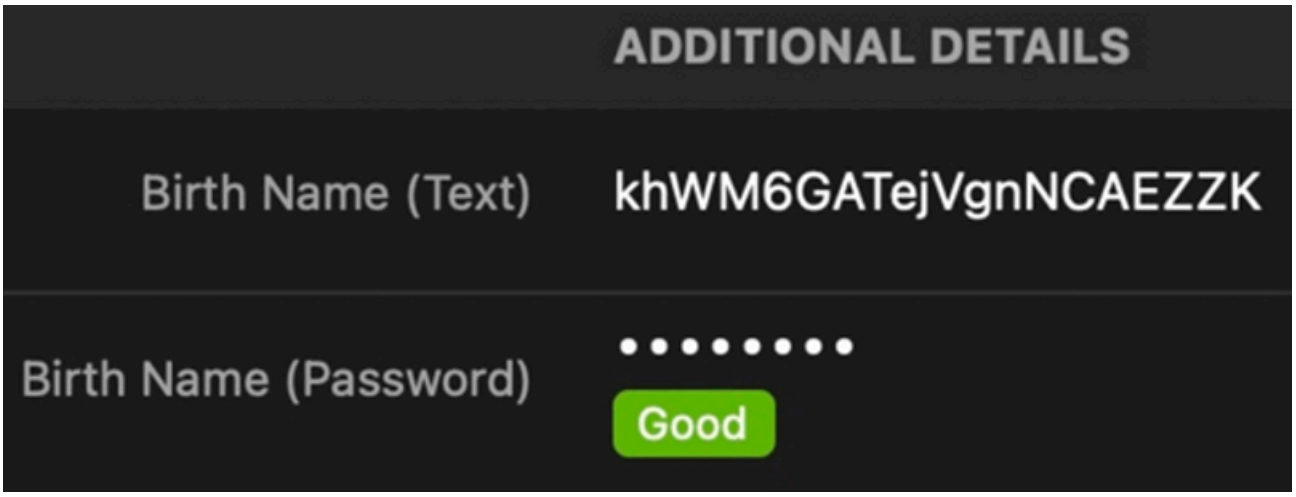


Figure 5: Knowledge-Based Authentication answers stored as "Text" vs "Password"

Using Real Data for Knowledge-Based Authentication Answers

Protecting the answers to KBA questions is all fine and dandy, but a diligent attacker could easily find the answers to most “secret” questions after a shockingly small amount of Open-Source Intelligence gathering (OSINT). Instead of answering KBA questions with answers pulled from your real life, take advantage of your password manager’s password/passphrase generator, and create answers that no rational human would ever guess. For example, you could tell your bank that your mother’s birth name is “khWM6GATejVgnNCAEZZK”!

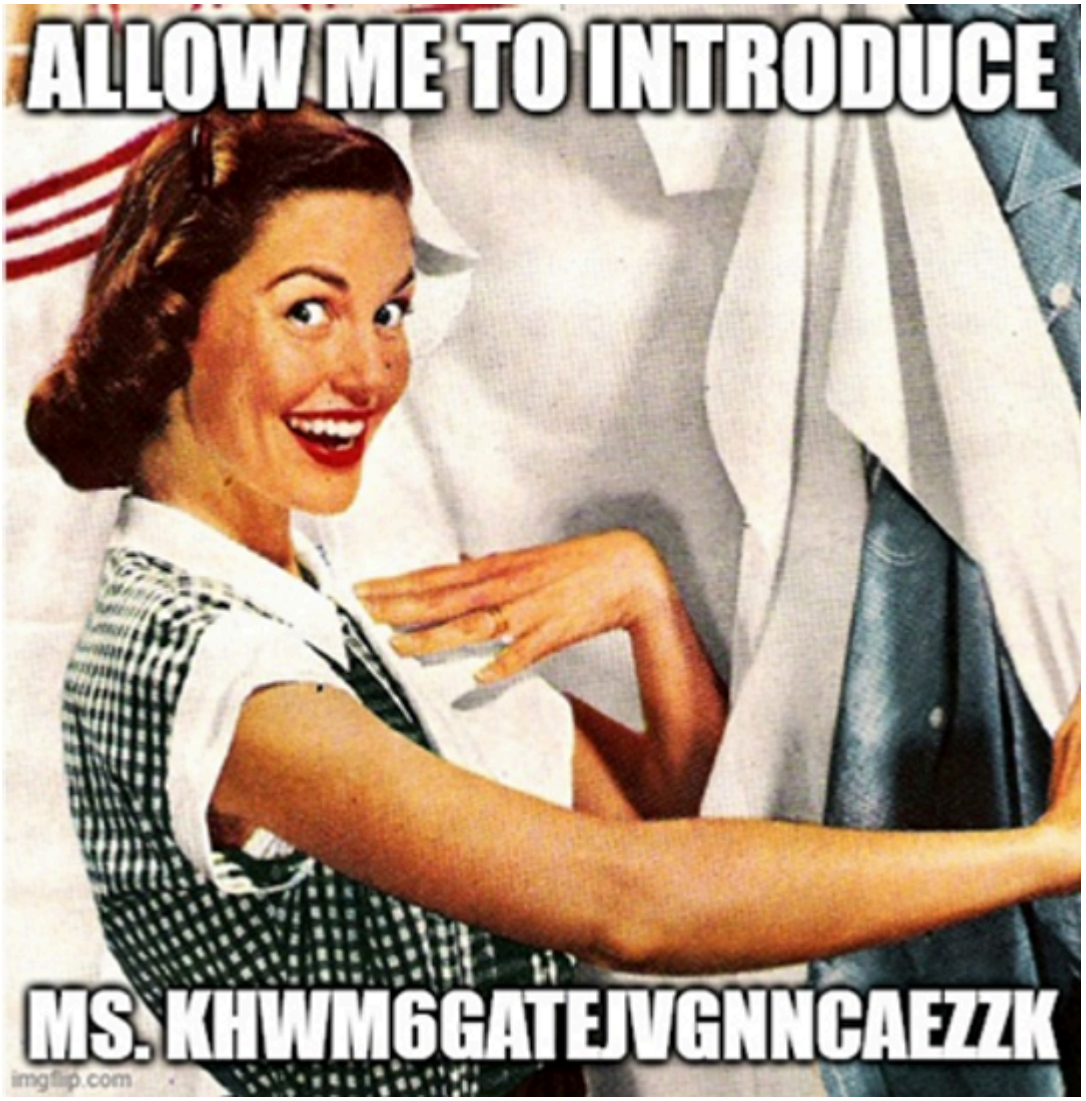


Figure 6: But you can just call her Kathi

If you choose to use generated passwords as answers to KBA questions, be sure to treat them just like you treat any other password:

- Create a unique answer for every question on a single site.
- Do not reuse one site's answers on another site.
- Ensure all answers are long, complex, and generated by a computer - not a human.

Not Using Multi-Factor Authentication

Most modern password managers support the use of one or more additional factors when unlocking the password manager for use. Unfortunately, unless you are using a truly separate device as your additional factor, that second factor is effectively meaningless. Thankfully, security professionals have already considered this situation and have developed an easy-to-use solution: the hardware key.

A hardware key is a close analog to a traditional key you would use in a door of your home. When you need to unlock your password manager, you provide your primary password then confirm the existence of the hardware key either by pressing a button on the key while it's inserted into your computer or by bringing the key close to your mobile device. Because this key is separate from the device containing the password manager app, the security level is far superior to any other multi-factor authentication method.



Figure 7: Hardware keys from various manufacturers

Oversharing

One of the most common misuses of password manager apps is oversharing. There are multiple methods to share your password with another person, but the least secure method – by far! - is to give them your primary password to your password manager. This may not seem important. You already trust the person you are sharing with; who cares if they can see your stuff? Like many situations in the security realm, this issue isn't so much about whether you trust the other person but instead increased attack surface.

When you share your primary password with another person, you have doubled your personal attack surface. An attacker can now compromise your trusted person to gain access to your information. How can we fix this? Password managers attempt to solve this problem by using vaults. A "vault" is a collection of passwords protected by a password manager. Modern password managers allow you to create multiple vaults and share those vaults with other people. This can be extremely useful in small teams or families that need to share account information among themselves.

In practice, most people do not utilize vaults at all. But even when vaults are used, they often include passwords that are not truly needed by all parties accessing the vault. To improve the security of this situation, create a secondary vault that contains ONLY the passwords you truly need to share. Give your trusted partner access to that vault via their own password manager account. DO NOT share your entire main vault!

Not Using Backup Authentication Factors

Let’s assume you’ve corrected every misconfiguration and weakness described above. Understandably, you’re feeling invincible right now. But consider this: what happens when you misplace your hardware key? Will you be locked out of your password manager and accounts forever?



Figure 8: Don't get locked out!

The first option for recovering access to your accounts after losing a hardware key is “recovery codes” aka “backup codes” aka “recovery keys”. Recovery codes are numbers or phrases that can be used in place of your second factor when that factor has been misplaced, destroyed, compromised, etc. Recovery codes should be provided to you when you enable a second factor, and these codes should be stored in physical form in a secure location.

Another option is to create a backup hardware key. Thankfully, most applications that permit the use of hardware keys also support the use of backup keys. This backup key should be kept in a very secure location and should not rely on your original key to be accessed! If you want to be VERY secure, Trimarc recommends creating a second backup

hardware key (three keys total) which is stored in an offsite location such as a safe deposit box.

Lastly, if you want to go full Nerd On Security, an affordable and environmentally responsible method of creating a backup factor is to run a TOTP application on old hardware such as a last-generation tablet or phone. You can install the exact same authenticator application on the older device and keep it in a secure location.

Wrapping Up!

Once upon a time, some people created computers. Shortly thereafter, some other people decided it would be fun to steal the stuff inside those computers. Thus, the password was born. But like any early technology, it was born to be obsolete and replaced by better, more secure methods of identification and authentication. Unfortunately, the replacement process has taken a little longer than we'd have liked. Whether due to misconfigurations, lax policies, or just sheer laziness, passwords as a sole means to secure data haven't passed muster for some time. It's our hope, through this blog, the methods many an enterprise have instituted can also trickle down to the user/consumer. Your laptop didn't come with biometrics, you say? Your password manager is your new best friend. Even your own security questions can be a lesson in creative writing because you can just lie to your heart's content. In fact, we encourage it.

An informed user is a powerful user. Go forth and secure your castle.

Sources:

Walden, David, and Tom Van Vleck. "Compatible Time-Sharing System (1961–1973) Fiftieth Anniversary Commemorative Overview." Website of the IEEE Computer Society History Committee, IEEE Computer Society, June 2011, http://history.computer.org/pubs/2011-06-ctss.pdf.

About Trimarc Security

We are the AD Security experts. From Active Directory configuration review to Azure & virtualization assessments to full on Purple Team engagements measuring risk and mapping attack paths, we have a service to fill your requirements.

For more information on Trimarc and our services, visit TrimarcSecurity.com


TRIMARC